

■ ■ Sistem Cuti Online Dishub Kota Bogor

PAPARAN KEAMANAN SISTEM

Bagaimana data pegawai dan proses cuti dilindungi

Sub Bagian Umum & Kepegawaian
KKL Ilmu Komputer — Universitas Djuanda

Ringkasan Keamanan yang Diterapkan

No	Lapisan Keamanan	Fungsi
1	CSRF Token	Mencegah form palsu dari website lain
2	Rate Limiting	Mencegah spam & serangan brute force
3	Security Headers	Anti-clickjacking, anti-sniffing, batasi sumber script
4	API Validasi Aman	Tidak membocorkan data pribadi pegawai
5	Password Terenkripsi	Password admin di-hash dengan bcrypt
6	Konfigurasi Wajib	Sistem menolak jalan tanpa SECRET_KEY aman
7	Data Pegawai Terlindungi	Template berisi data asli tidak masuk repository
8	Anti-Bypass Proxy	Header X-Forwarded-For hanya dipercaya dari proxy resmi

Seluruh lapisan di atas berjalan otomatis di setiap permintaan (request) ke sistem.

1. Anti-Pemalsuan Form (CSRF)

SUDAH DITERAPKAN

CSRF (Cross-Site Request Forgery) adalah serangan di mana website jahat mengirimkan data atas nama korban tanpa sepengetahuan korban.

Cara kerja proteksinya:

- Setiap form (pengajuan cuti, cek status, login admin) diberi **token rahasia unik**
- Token disimpan di sesi pengguna dan dikirim bersama form
- Server memverifikasi token **sebelum** memproses data
- Permintaan tanpa token valid ditolak (403 Forbidden)

***Manfaat:** Walaupun seseorang membuat website tiruan, form palsu dari website tersebut tidak akan pernah diterima oleh sistem.*

***Verifikasi cepat:** Kirim form tanpa token → sistem merespons 403 Forbidden.*

2. Anti-Spam & Anti-Brute Force (Rate Limiting)

SUDAH DITERAPKAN

Sistem membatasi jumlah permintaan dari satu alamat IP dalam periode tertentu. Ini menghentikan bot, script otomatis, dan percobaan tebak kata sandi.

Aktivitas	Batas Maksimal	Periode
Submit form pengajuan cuti	10 kali	1 jam
Validasi NIP (API)	30 kali	1 menit
Cek status pengajuan	20 kali	1 menit
Login admin gagal	5 kali	Terkunci 15 menit

Manfaat: Pengguna normal tidak akan pernah merasakan pembatasan ini — hanya bot dan penyerang yang terhenti.

3. Security Headers (Proteksi Browser)

SUDAH DITERAPKAN

Setiap halaman yang dikirim sistem dilengkapi header keamanan yang diperintahkan ke browser untuk berperilaku aman:

Header	Fungsi	Mencegah
X-Frame-Options	Halaman tidak bisa dibungkus iframe website lain	Clickjacking
X-Content-Type-Options	Browser tidak menebak jenis file	MIME sniffing
Content-Security-Policy	Hanya script/style dari sumber resmi yang dimuat	Serangan XSS

Manfaat: Walaupun ada celah, browser menolak mengeksekusi hal yang berbahaya.

4. API Validasi NIP — Tanpa Kebocoran Data

SUDAH DITERAPKAN

API validasi NIP sengaja dirancang **hanya menjawab 'terdaftar atau tidak'**. Tidak ada data pribadi yang dikembalikan.

Permintaan	Respons API	Keterangan
NIP terdaftar	{"valid": true}	Hanya konfirmasi
NIP tidak terdaftar	{"valid": false}	Hanya penolakan
Format salah	400 Bad Request	Input ditolak

- Nama, jabatan, seksi, dan data pribadi lainnya **tidak pernah** dikirim lewat API
- Pegawai mengisi data pribadi secara manual setelah NIP dinyatakan valid
- Sistem tidak bisa dimanfaatkan untuk 'mengintip' data pegawai lain

Manfaat: Siapa pun yang mengetahui NIP tidak dapat mengambil data pribadi pegawai lain dari sistem.

5. Password Terenkripsi & Konfigurasi Aman

SUDAH DITERAPKAN

Password Admin — di-hash dengan bcrypt

- Password tidak pernah disimpan sebagai teks biasa
- bcrypt adalah standar industri untuk penyimpanan kata sandi
- Bahkan jika data bocor, password tidak dapat dibaca/dibalik

Konfigurasi wajib sebelum berjalan

- Sistem menolak start jika kunci rahasia (SECRET_KEY) belum diset atau masih default
- Mencegah deployment yang tidak sengaja memakai konfigurasi tidak aman
- IP pengguna tidak bisa dipalsukan untuk melewati batas akses (anti-bypass)

Manfaat: Sistem dirancang agar tidak mungkin ter-deploy dalam keadaan tidak aman.

6. Data Pegawai Terlindungi

SUDAH DITERAPKAN

File yang berisi data pegawai asli (template surat cuti) **tidak disimpan di repository publik.**

- Template surat berisi contoh nama & data pegawai nyata dikeluarkan dari repository
- Riwayat git dibersihkan sehingga data tidak bisa dilacak kembali
- Repository hanya berisi kode program — tanpa data pribadi

Nama sheet juga dikonfigurasi via variabel

- Nama sheet ('CUTI 2026', 'DATA_KARYAWAN') dikelola lewat satu file konfigurasi
- Tidak ada nama sheet yang tersebar di kode program
- Perubahan nama sheet cukup dilakukan di satu tempat

Rekomendasi Tahap Selanjutnya

DISARANKAN — TAHAP PRODUCTION

No	Peningkatan	Keterangan	Prioritas
1	HTTPS / SSL	Enkripsi data saat dikirim melalui jaringan	Tinggi
2	Audit Log	Catatan siapa mengubah status pengajuan & kapan	Sedang
3	Backup Otomatis	Cadangan data Google Sheets secara berkala	Sedang
4	Login Karyawan	Sesi login per pegawai, bukan hanya NIP + tanggal lahir	Rendah

Keamanan dasar sudah solid. Peningkatan di atas direkomendasikan sebelum sistem digunakan secara luas di lingkungan Dishub.

Terima kasih. — Sub Bagian Umum & Kepegawaian, KKL Ilmu Komputer Universitas Djuanda